

FLUTTER_BACKEND_INTEGRATION_SPEC.md

CanlıFal — Flutter ↔ Mevcut Backend Entegrasyon Sözleşmesi

Tarama tarihi: 2026-09-12 · **Kaynak:** üretim kodu (549 rota dosyası, 852 endpoint, 231 model, 95 servis modülü)

Bu belge üretilirken backend’de hiçbir değişiklik yapılmamıştır.

Temel kural: WEB + FLUTTER → **AYNI BACKEND** → **AYNI VERİTABANI**. Flutter için ayrı backend mantığı yoktur ve olmayacaktır.

Kaynakta doğrulanamayan her konu **MISSING** ile işaretlenmiştir. Varsayılan endpoint/olay adı kullanılmamıştır.

1. Base URL

Ortam	Base URL
Üretim	https://canlifal.com/api
Sürümlü eşdeğeri	https://canlifal.com/api/v1

`middleware.ts` (satır 14–23, matcher 134–137) `/api/v1/:path*` isteğini `/api/*` rotasına **rewrite** eder ve yanıtı `x-api-version: v1` başlığını ekler. Yani `/api/wallet` ile `/api/v1/wallet` **aynı** rotadır. Flutter’da `/api/v1` kullanmanız önerilir (ileride sürümleme yapılabilir).

2. Environment

- Tek üretim ortamı: `canlifal.com`. Ayrı bir staging alan adı **yoktur (MISSING)**.
- Flutter’da `--dart-define=API_BASE_URL=...` ile derleme zamanı yapılandırması kullanın; URL’i kod içine gömmeyin.
- Zaman damgaları ISO-8601 UTC’dır. Sunucu saat dilimi UTC.
- Dil: `preferredLanguage` kullanıcı alanında tutulur; içerik uçları `tr` / `en` destekler.

3. Authentication

Ayrıntılı anlatım: `authentication.md`.

Çift kimlik doğrulama deseni. Korumalı her rota önce `Authorization: Bearer <token>` mobil JWT’sini dener, yoksa web oturum çerezine düşer (`lib/rbac.ts` → `resolveUser()`), saf mobil uçlarda `lib/mobile-auth.ts` → `authenticateRequest()`).

Uç	Gövde	Yanıt
POST /api/auth/mobile-login	{ email \ username, password }	{ accessToken, refreshToken, user{...} }
POST /api/auth/mobile-refresh	{ refreshToken }	{ accessToken, refreshToken, user{...} }

- accessToken ömrü **7 gün**, refreshToken **30 gün** (lib/mobile-auth.ts). HS256. Payload: { userId, email, role, type }.
- user nesnesi: id, email, name, username, role, image, credits, jetonBalance, cfcBalance, membership, membershipExpiresAt, preferredLanguage, level, bio, phone, birthDate, zodiacSign, referralCode.
- Giriş rate limiti: authLimiter = **10 istek / 15 dakika**, IP anahtarlı (mobile-login:\${ip}) → aşım da 429 "Çok fazla istek. Lütfen biraz bekleyin."
- Hatalı kimlik → 401 "E-posta veya şifre hatalı".
- **MISSING:** telefon numarası ile giriş (login), sosyal giriş (Facebook/Apple). (Not: çıkış/token iptali, oturum listesi, hesap silme BÖLÜM 14'te; telefon/SMS OTP ve e-posta doğrulama BÖLÜM 17'de eklendi.)

4. Headers

Başlık	Ne zaman	Değer
Authorization	Korumalı tüm çağrılar	Bearer <accessToken>
Content-Type	Gövdeli isteklerde	application/json
Idempotency-Key	Para/hediye/çekim/üyelik işlemlerinde	UUID v4, 24 sa geçerli
X-Idempotency-Key	Idempotency-Key alternatifi	aynı
Accept	SSE bağlantılarında	text/event-stream

Yanıta gelen: x-api-version: v1 , ayrıca lib/api-response.ts → getRequestId() ile istek kimliği.

5. REST APIs

852 ucun tamamı makine okunur biçimde şu dosyalardadır:

- openapi.yaml — OpenAPI 3.0, 549 path / 852 operasyon / 110 etiket
- endpoints_index.json — her uç için path, method, file, auth[], admin, sse, rateLimit, idempotent, audit, ledger, criticalConfirm, pathParams[], queryParams[], bodyFields[], tag
- ENDPOINTS.md — insan okunur tam liste
- postman_collection.json — Postman koleksiyonu

Alan bazlı ayrıntı belgeleri: voice_room_api.md , live_stream_api.md , gifts_coins_wallet_api.md , ranking_api.md , admin_permissions.md .

Dağılım: **366** admin · **399** mobil JWT kabul eden · **133** public · **20** SSE.

6. WebSocket

● **WebSocket sunucusu YOKTUR.** Socket.IO, ws veya GraphQL subscription **yoktur.** Kaynak taramasıyla doğrulanmıştır. Flutter'da WebSocket istemcisi yazmayın.

Gerçek zamanlılık üç mekanizmayla sağlanır:

1. **SSE** (`text/event-stream`) — 20 uç, 6'sı kalıcı kanal
2. **Polling** — `?since=<timestamp>` sorgu parametresi
3. **TRTC/WebRTC** — ses/görüntü taşıma

7. Real-time Events

Tam liste, olay adları, yön (S→C / C→S), payload ve tetikleyici: `websocket_events.md` .

Kalıcı SSE kanalları:

Kanal	Amaç
<code>GET /api/chat/rooms/[roomId]/stream</code>	Sesli oda olayları
<code>GET /api/room/[sessionId]/stream</code>	Falci seansı
<code>GET /api/video-streams/[streamId]/stream</code>	Canlı yayın
<code>GET /api/pk/[matchId]/stream</code>	PK maçı
<code>GET /api/fortune-tellers/sessions/stream</code>	Falci seans kuyruğu
<code>GET /api/notifications/stream</code>	Bildirimler

Ayrıca `/api/fortunes/*` altında 14 adet LLM token akışı yapan POST ucu vardır.

8. Models

231 veri modeli / 2.811 alan:

- `DATA_MODELS.md` — insan okunur
- `data_models.json` — makine okunur
- `database_schema.sql` — tam DDL (6.362 satır)
- `kaynak/prisma/schema.prisma` — şema kaynağı

● **Flutter veritabanına DOĞRUDAN BAĞLANMAZ.** Şema yalnızca model sınıfları üretmek ve alan adlarını doğrulamak içindir. Tüm erişim REST üzerindendir.

9. Error Handling

İki yanıt biçimi bir arada kullanılır — istemci **ikisini de** çözmelidir:

A) { "error": "Yetersiz jeton" }
 B) { "success": false, "error": { "code": "INSUFFICIENT_BALANCE", "message": "...", "meta": {...} } }

Kod	Anlam	Flutter davranışı
400	Doğrulama / iş kuralı	Kullanıcıya mesajı göster
401	Token yok/geçersiz/süresi doldu	Refresh dene → başarısızsa çıkış
403	Yetki yok	Ekranı kısıtla
404	Kayıt yok	Boş durum
409	Çakışma veya kritik onay gerekli	<code>requiresConfirmation</code> varsa onay diyalogu → <code>confirm:true</code> ile tekrar
422	Semantik doğrulama	Alan hatası göster
429	Rate limit	Üstel geri çekilme
500	Sunucu hatası	Genel hata + tekrar dene

`ErrorCodes` sabitleri (`lib/api-response.ts`), örnek: `VALIDATION_ERROR`, `UNAUTHORIZED`, `FORBIDDEN`, `TOKEN_EXPIRED`, `TOKEN_INVALID`, `REFRESH_TOKEN_EXPIRED`, `ACCOUNT_BANNED`, `INVALID_CREDENTIALS`, `INSUFFICIENT_CREDITS`, `INSUFFICIENT_BALANCE`, `PAYMENT_ALREADY_PROCESSED`, `IDEMPOTENCY_CONFLICT`, `ROOM_FULL`, `SEAT_OCCUPIED`, `STREAM_ENDED`, `GIFT_SEND_FAILED`, `PK_ALREADY_ACTIVE`, `RATE_LIMITED`, `INTERNAL_ERROR` ...

Sayfalama iki moddardır (`lib/pagination.ts`): `offset ( page , limit )` ve `cursor ( cursor , limit )`. Tek bir liste yükleyicide her ikisini destekleyin.

10. File Upload

POST /api/upload/presigned — mobil JWT

Gövde: { `fileName`, `contentType`, `isPublic = false`, `folder` }

Yanıt: { `uploadUrl`, `cloud_storage_path`, `publicUrl` } (`publicUrl`, `isPublic=false` iken `null`)

Akış: `presigned` al → dönen `uploadUrl` 'e dosyayı **doğrudan PUT** et → ilgili kaynağa `cloud_storage_path` değerini gönder.

Klasör eşlemesi: `profile|profiles` → `gift/profiles` · `social|sosyal|post` → `gift/social` · `gift|gifts` → `gift/gifts` · `fortune` → `gift/fortunes` · `chat` → `gift/chat` · `uploads` → `gift/uploads` (varsayılan).

Yalnız `image/*` ve `video/*` kabul edilir → aksi hâlde 400 "Sadece görsel ve video dosyaları kabul edilir".

Alternatifler: `GET|POST /api/upload/get-url`, `POST /api/short-videos/upload-url`.

11. Notifications

- Liste / okundu işaretle / sil: `GET · POST · DELETE /api/notifications` (gövde `notificationIds`, `markAll`)
- Canlı akış: `GET /api/notifications/stream` (SSE)
- Cihaz kaydı: `POST /api/devices/fcm` gövde `{ token, platform: 'android'|'ios'|'web', appVersion? }` → `{ success: true, deviceId }`; token en az 10 karakter olmalı, değilse 400 "Geçerli bir push token gerekli". Çıkışta `DELETE /api/devices/fcm` gövde `{ token }`.
- Gönderim sağlayıcısı: `lib/push.ts` → `PUSH_PROVIDER = 'onesignal'`. Flutter'da **OneSignal SDK** kullanın; alınan `player/push token`'ı `/api/devices/fcm` ile kaydedin.
- Derin bağlantı: `lib/deeplink.ts`, şema `canlifal://<type>/<value>`; türler: `teller`, `room`, `stream`, `video`, `post`, `blog`, `profile`, `chatroom`, `dream`, `dreamdict`, `page`, `message`, `question`, `home`.

12. Voice Rooms

Tam belge: `voice_room_api.md`. Özet: `GET /api/chat/rooms` → `POST /api/chat/rooms/create` → `POST /api/chat/rooms/[roomId]/presence` (giriş/heartbeat) → `GET .../state` + `GET .../stream` (SSE) → `koltuk PATCH .../seats` → `mikrofon .../voice`, `söz isteği .../speak-request(s)` → `müzik .../music`, `.../music-queue`, `.../song-request`, `DJ .../dj` → `moderasyon .../moderation` → `PK .../pk`.

⚠ `.../join` ucu **yoktur**.

13. Live Streams

Tam belge: `live_stream_api.md`. Özet: `POST /api/video-streams` → TRTC bağlan → `POST .../live-started` → periyodik `POST .../media-heartbeat` (kesilirse yayın otomatik kapanır) → izleyici `POST .../join`, SSE `.../stream` → `POST .../end`.

⚠ RTMP/HLS/stream-key ucu **yoktur (MISSING)** — TRTC zorunludur.

14. Gifts

Tam belge: `gifts_coins_wallet_api.md`. `POST /api/gifts/send` (gövde `type`, `giftTypeId`, `jetonAmount`, `recipientUsername`), katalog `GET /api/gifts/catalog`, sürüm `GET /api/gifts/version`, bağlam uçları oda/yayın altında. **Idempotency zorunlu**.

15. Coins (Jeton)

`GET /api/wallet` → `{ coins, jetonBalance, cfcBalance, credits }` · `GET / POST /api/jeton` · `GET /api/public/jeton-price` · paketler `GET /api/credit-packages` · çekim `GET / POST /api/withdrawals`. Jeton **çekilebilir** birimdir.

16. CFC

`User.credits` alanı (`cfcBalance` olarak da döner). Ödül birimidir, **nakde çevrilemez**. Kazanım yolları: günlük giriş (`POST /api/jeton {action:'daily_login'}` → +5 CFC), görevler, turnuva/sıralama ödülleri. Her hareket `recordLedger` ile çift taraflı yazılır.

17. Gold

User.membership (basic / gold / diamond) + membershipExpiresAt . Planlar GET /api/membership/plans , satın alma POST /api/memberships/purchase (planId , paymentMethod) — **idempotent**, süre hesabı sunucuda. Rozetler GET /api/membership-badges . Gold girişi odalarda animasyonlu olay üretir (bkz. websocket_events.md).

18. PK

Oda PK'sı /api/chat/rooms/[roomId]/pk , yayın PK'sı /api/video-streams/[streamId]/pk-battle ve /api/video-streams/pk* , ortak uçlar /api/pk/* (aktif, maç detayı, SSE, davetler, liderlik).

 pk/score uçları **admin-only**; gerçek skor lib/gift-pk-score.ts → applyGiftPkScore ile hediyelerden sunucuda üretilir. Durum makinesi lib/pk-state.ts .

19. Ranking

Tam belge: ranking_api.md . GET /api/leaderboards (30 sn ön bellek, currentUserRanks dâhil), GET /api/leaderboards/top100 , turnuvalar GET /api/tournaments . Puan artışı için istemci ucu **yoktur**; motor lib/leaderboard-engine.ts .

20. Admin

Tam belge: admin_permissions.md . 366 admin korumalı uç, guard'lar lib/rbac.ts (+ cosmetics , animation-admin , ad-placements), 90+ recordAudit çağrısı, \$88 kritik onay eşikleri { jeton: 1000, cfc: 5000, amountTl: 2000 } .

21. Permissions

Roller: user , fortune_teller , agency , moderator , finans , yonetici , admin .

Yetki kararı **her zaman sunucudadır**. İstemci rol bilgisini yalnızca UI gizlemek için kullanır; gerçek karar 403 yanıtıdır. API rotaları middleware kimlik doğrulamasının dışındadır — her rota kendi guard'ını çalıştırır.

22. Security

Katman	Uygulama
Rate limit	<code>apiLimiter 60/60sn · authLimiter 10/15dk · heavyLimiter 10/60sn (lib/rate-limiter.ts)</code>
Idempotency	<code>Idempotency-Key , 24 sa TTL (lib/idempotency.ts)</code>
Kritik işlem onayı	<code>409 requiresConfirmation + confirm:true (lib/critical-confirm.ts)</code>
Denetim	<code>90+ recordAudit</code>
Muhasebe	<code>Çift taraflı ledger (lib/ledger.ts)</code>
PK manipölasyonu	Skor uçları admin-only (\$90 düzeltmesi)
Ödeme tekrarı	<code>creditApplied</code> bayrağı
Hediye tekrarı	<code>beginIdempotent / completeIdempotent</code>
Çekim	Bakiye + limit + minimum + bekleyen + rate limit + idempotency

MISSING: refresh token kara listesi / iptali; SSE `Last-Event-ID` tekrar oynatma doğrulanmadı; cihaz bazlı oturum yönetimi yok.

23. Example Requests

```
POST /api/v1/auth/mobile-login HTTP/1.1
Host: canlifal.com
Content-Type: application/json

{ "email": "kullanici@example.com", "password": "*****" }
```

```
GET /api/v1/wallet HTTP/1.1
Host: canlifal.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIs...
```

```
POST /api/v1/gifts/send HTTP/1.1
Host: canlifal.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIs...
Content-Type: application/json
Idempotency-Key: 1f3d0b2a-8c4e-4b21-9a77-6f0e2c9d1b55

{ "type": "gift", "giftTypeId": "<giftTypeId>", "recipientUsername": "kullanici" }
```

```
GET /api/v1/chat/rooms/<roomId>/stream HTTP/1.1
Host: canlifal.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIs...
Accept: text/event-stream
```

24. Example Responses

POST /api/auth/mobile-login → 200

```
{
  "accessToken": "eyJ...",
  "refreshToken": "eyJ...",
  "user": {
    "id": "...", "email": "...", "name": "...", "username": "...",
    "role": "user", "image": null,
    "credits": 55, "jetonBalance": 0, "cfcBalance": 55,
    "membership": "basic", "membershipExpiresAt": null,
    "preferredLanguage": "tr", "level": 1,
    "bio": null, "phone": null, "birthDate": null,
    "zodiacSign": null, "referralCode": "..."
  }
}
```

GET /api/wallet → 200

```
{ "coins": 0, "jetonBalance": 0, "cfcBalance": 55, "credits": 55 }
```

POST /api/gifts/send → 200

```
{ "success": true,
  "message": "Gül hediyesi kullanıcı kişisine gönderildi! 📁",
  "bigGift": null }
```

POST /api/gifts/send → 400

```
{ "error": "Yetersiz jeton" }
```

POST /api/admin/payments → 409

```
{ "requiresConfirmation": true,
  "confirmationMessage": "5.000 jeton yüklemek istediğinize emin misiniz? (Ad Soyad)",
  "action": "jeton_adjust" }
```

POST /api/upload/presigned → 200

```
{ "uploadUrl": "https://...", "cloud_storage_path": "gift/uploads/...", "publicUrl":
  null }
```


25. Flutter Integration Notes

1. **Tek HTTP istemcisi** (Dio önerilir) + interceptor zinciri: `Authorization` ekleme → `401` refresh → `429` backoff → `409` `requiresConfirmation` onay → çift hata biçimi ayrıştırma.
2. **Token depolama:** `flutter_secure_storage`. Access 7 gün, refresh 30 gün.
3. **SSE:** Dio/ http üzerinde chunked stream ile okuyun; kopmada üstel geri çekilmeli yeniden bağlanma + bağlanınca ilgili `state / detail` ucunu yeniden çekin (`Last-Event-ID` desteği doğrulanmadı).
4. **TRTC SDK** ses ve görüntü için zorunlu; imza `POST /api/trtc/usersig`.
5. **Yayıncı ekranında Android foreground service** — `media-heartbeat` kesilirse yayın sunucu tarafından kapatılır.
6. **OneSignal SDK** + `POST /api/devices/fcm`; çıkışta `DELETE`.
7. **Deep link:** `canlifal://` şeması, 14 tür; Android `intent-filter` ile eşleyin.
8. **Model üretimi:** `openapi.yaml` + `data_models.json` üzerinden kod üretimi yapın; alan adlarını elle yazmayın.
9. **İstemciye taşınmayacaklar:** jeton/CFC hesabı, hediye işlemi, sıralama puanı, yetki kararı, Gold süresi, PK sonucu, cüzdan bakiyesi, işlem kaydı. Hepsi sunucudadır ve öyle kalmalıdır.
10. **Veritabanına doğrudan bağlanmak yasaktır.**

Ek — Sosyal / profil / yükleme uçları tam tablosu

Toplam **85** endpoint (path+method). Kaynak: üretim kodu taraması, 2026-09-12.

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
GET	/api/messages	mobil JWT	—	unread-Count	—	app/api/messages/route.ts
GET	/api/messages/[userId]	mobil JWT	RL	—	content, imageUrl	app/api/messages/[userId]/route.ts
POST	/api/messages/[userId]	mobil JWT	RL	—	content, imageUrl	app/api/messages/[userId]/route.ts
PATCH	/api/messages/request	mobil JWT	—	—	action, message, receiverId, requestId	app/api/messages/request/route.ts
POST	/api/messages/request	mobil JWT	—	—	action, message, receiverId, requestId	app/api/messages/request/route.ts
DELETE	/api/notifications	mobil JWT	—	id, page, unreadOnly	markAll, notificationIds	app/api/notifications/route.ts
GET	/api/notifications	mobil JWT	—	id, page, unreadOnly	markAll, notificationIds	app/api/notifications/route.ts
POST	/api/notifications	mobil JWT	—	id, page, unreadOnly	markAll, notificationIds	app/api/notifications/route.ts
GET	/api/notifications/stream	mobil JWT	SSE	—	—	app/api/notifications/stream/route.ts

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
GET	/api/profile-frames	mobil JWT	—	—	frameId	app/api/profile-frames/route.ts
POST	/api/profile-frames	mobil JWT	—	—	frameId	app/api/profile-frames/route.ts
GET	/api/short-videos	mobil JWT	—	cursor, limit, tab	—	app/api/short-videos/route.ts
DELETE	/api/short-videos/[id]	mobil JWT	ADMIN	—	—	app/api/short-videos/[id]/route.ts
GET	/api/short-videos/[id]	mobil JWT	ADMIN	—	—	app/api/short-videos/[id]/route.ts
GET	/api/short-videos/[id]/comments	mobil JWT	RL	limit, parentId	—	app/api/short-videos/[id]/comments/route.ts
POST	/api/short-videos/[id]/comments	mobil JWT	RL	limit, parentId	—	app/api/short-videos/[id]/comments/route.ts
DELETE	/api/short-videos/[id]/com-	mobil JWT + web oturum	ADMIN	—	—	app/api/short-videos/[id]/com-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
	ments/ [comment-Id]					ments/ [comment-Id]/ route.ts
POST	/api/ short-videos/ [id]/com-ments/ [comment-Id]/like	mobil JWT	—	—	—	app/api/ short-videos/ [id]/com-ments/ [comment-Id]/like/ route.ts
POST	/api/ short-videos/ [id]/com-ments/ [comment-Id]/pin	mobil JWT	ADMIN	—	—	app/api/ short-videos/ [id]/com-ments/ [comment-Id]/pin/ route.ts
GET	/api/ short-videos/ [id]/duets	mobil JWT	—	cursor, limit	—	app/api/ short-videos/ [id]/duets/ route.ts
POST	/api/ short-videos/ [id]/like	mobil JWT	—	—	—	app/api/ short-videos/ [id]/like/ route.ts
POST	/api/ short-videos/ [id]/save	mobil JWT	—	—	—	app/api/ short-videos/ [id]/save/ route.ts
POST	/api/ short-videos/	mobil JWT	—	—	—	app/api/ short-videos/ [id]/

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
	[id]/share					share/ route.ts
POST	/api/short-videos/[id]/view	mobil JWT	—	—	—	app/api/short-videos/[id]/view/ route.ts
GET	/api/short-videos/explore	mobil JWT	—	cursor, limit, q	—	app/api/short-videos/explore/ route.ts
GET	/api/short-videos/mentions/search	public	—	limit, q	—	app/api/short-videos/mentions/search/ route.ts
GET	/api/short-videos/music	public	—	limit, q	—	app/api/short-videos/music/ route.ts
GET	/api/short-videos/profile/[userId]	mobil JWT	—	—	—	app/api/short-videos/profile/[userId]/ route.ts
POST	/api/short-videos/register	mobil JWT	—	—	—	app/api/short-videos/register/ route.ts
POST	/api/short-videos/upload	mobil JWT	RL	—	—	app/api/short-videos/up-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
						load/ route.ts
POST	/api/ short- videos/up- load-url	mobil JWT	—	—	—	app/api/ short- videos/up- load-url/ route.ts
GET	/api/ short- videos/ user/ [userId]	mobil JWT	—	cursor, lim- it, tab	—	app/api/ short- videos/ user/ [userId]/ route.ts
GET	/api/ social/ posts	mobil JWT	RL	limit, page, type	content, fortuneld, fortune- Type, im- ageUrl, isPublic, postType, youtubeUrl	app/api/ social/ posts/ route.ts
POST	/api/ social/ posts	mobil JWT	RL	limit, page, type	content, fortuneld, fortune- Type, im- ageUrl, isPublic, postType, youtubeUrl	app/api/ social/ posts/ route.ts
DELETE	/api/ social/ posts/ [postId]	mobil JWT	ADMIN	—	—	app/api/ social/ posts/ [postId]/ route.ts
GET	/api/ social/ posts/ [postId]	mobil JWT	ADMIN	—	—	app/api/ social/ posts/ [postId]/ route.ts

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
DELETE	/api/ social/ posts/ [postId]/ comments	mobil JWT	ADMIN, RL	commentId	content	app/api/ social/ posts/ [postId]/ comments/ route.ts
GET	/api/ social/ posts/ [postId]/ comments	mobil JWT	ADMIN, RL	commentId	content	app/api/ social/ posts/ [postId]/ comments/ route.ts
POST	/api/ social/ posts/ [postId]/ comments	mobil JWT	ADMIN, RL	commentId	content	app/api/ social/ posts/ [postId]/ comments/ route.ts
POST	/api/ social/ posts/ [postId]/ likes	mobil JWT	—	—	—	app/api/ social/ posts/ [postId]/ likes/ route.ts
POST	/api/ social/ posts/ [postId]/ view	public	—	—	—	app/api/ social/ posts/ [postId]/ view/ route.ts
GET	/api/ upload/ get-url	mobil JWT	—	path	—	app/api/ upload/ get-url/ route.ts
POST	/api/ upload/ get-url	mobil JWT	—	path	—	app/api/ upload/ get-url/ route.ts

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
POST	/api/upload/presigned	mobil JWT	—	—	—	app/api/upload/presigned/route.ts
GET	/api/user/[userId]/achievements	mobil JWT	—	—	—	app/api/user/[userId]/achievements/route.ts
DELETE	/api/user/[userId]/follow	mobil JWT	—	—	—	app/api/user/[userId]/follow/route.ts
POST	/api/user/[userId]/follow	mobil JWT	—	—	—	app/api/user/[userId]/follow/route.ts
GET	/api/user/[userId]/follow-status	mobil JWT	—	—	—	app/api/user/[userId]/follow-status/route.ts
GET	/api/user/achievements	mobil JWT	—	—	—	app/api/user/achievements/route.ts
GET	/api/user/active-sessions	mobil JWT	—	—	—	app/api/user/active-sessions/route.ts
GET	/api/user/activity	mobil JWT	—	—	—	app/api/user/

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
				limit, page, type, unread		activity/ route.ts
PATCH	/api/user/activity	mobil JWT	—	limit, page, type, unread	—	app/api/ user/ activity/ route.ts
GET	/api/user/block	mobil JWT	—	—	userId	app/api/ user/ block/ route.ts
POST	/api/user/block	mobil JWT	—	—	userId	app/api/ user/ block/ route.ts
DELETE	/api/user/blocked	mobil JWT	—	—	id, type	app/api/ user/ blocked/ route.ts
GET	/api/user/blocked	mobil JWT	—	—	id, type	app/api/ user/ blocked/ route.ts
GET	/api/user/broadcast-history	mobil JWT	—	limit, page, status	—	app/api/ user/ broadcast- history/ route.ts
GET	/api/user/co-broadcast-invites	mobil JWT	—	—	—	app/api/ user/co- broadcast- invites/ route.ts
GET	/api/user/credits	mobil JWT	—	—	—	app/api/ user/cred- its/ route.ts

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
GET	/api/user/followers	mobil JWT	—	userId	—	app/api/user/followers/route.ts
GET	/api/user/following	mobil JWT	—	userId	—	app/api/user/following/route.ts
GET	/api/user/fortunes	mobil JWT	—	pinned, saved	—	app/api/user/fortunes/route.ts
PATCH	/api/user/fortunes/[fortuneId]	mobil JWT	—	—	—	app/api/user/fortunes/[fortuneId]/route.ts
GET	/api/user/likers	mobil JWT	—	userId	—	app/api/user/likers/route.ts
GET	/api/user/profile	mobil JWT	—	—	—	app/api/user/profile/route.ts
PATCH	/api/user/profile	mobil JWT	—	—	—	app/api/user/profile/route.ts
GET	/api/user/received-gifts	mobil JWT	—	—	—	app/api/user/received-gifts/route.ts
GET		web oturum	—	limit, offset, type	—	app/api/user/referral-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
	/api/user/referral-earnings					earnings/ route.ts
POST	/api/user/report	mobil JWT	RL	—	details, reason, userId	app/api/ user/ report/ route.ts
GET	/api/user/statistics	mobil JWT	—	—	—	app/api/ user/statistics/ route.ts
GET	/api/user/stats	mobil JWT	—	—	—	app/api/ user/ stats/ route.ts
POST	/api/user/stats	mobil JWT	—	—	—	app/api/ user/ stats/ route.ts
GET	/api/user/theme	mobil JWT	—	—	theme	app/api/ user/ theme/ route.ts
PATCH	/api/user/theme	mobil JWT	—	—	theme	app/api/ user/ theme/ route.ts
GET	/api/user/wallet	mobil JWT + web oturum	—	currency, limit, offset	—	app/api/ user/ wallet/ route.ts
GET	/api/user/watch-ad	mobil JWT	—	—	—	app/api/ user/ watch-ad/ route.ts
POST	/api/user/watch-ad	mobil JWT	—	—	—	app/api/ user/

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
						watch-ad/ route.ts
GET	/api/user/ xp	mobil JWT	—	—	—	app/api/ user/xp/ route.ts
GET	/api/ users/ [userId]	mobil JWT	—	—	—	app/api/ users/ [userId]/ route.ts
GET	/api/ users/ [userId]/ follow	mobil JWT	—	type	—	app/api/ users/ [userId]/ follow/ route.ts
POST	/api/ users/ [userId]/ follow	mobil JWT	—	type	—	app/api/ users/ [userId]/ follow/ route.ts
GET	/api/ users/ [userId]/ posts	mobil JWT	—	limit, page, type	—	app/api/ users/ [userId]/ posts/ route.ts
GET	/api/ users/ lookup/ [user- name]	mobil JWT	—	—	—	app/api/ users/ lookup/ [user- name]/ route.ts
GET	/api/ users/on- line	public	—	—	—	app/api/ users/on- line/ route.ts
GET	/api/ users/ search	mobil JWT	—	q	—	app/api/ users/

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
						search/ route.ts

BÖLÜM 26 — 2026-09-12 GERÇEK KOD GÜNCELLEMESİ VE §21 KARARININ REVİZYONU

Önceki sürümde §21 kararı **KISMEN (PARTIALLY)** idi ve 10 madde “öneri” olarak bırakılmıştı. Bu sürümde bunların çoğu **gerçek kod olarak uygulanmıştır**.

Uygulananlar

Madde	Durum	Nerede
Hesap silme	✓ uygulandı	app/api/user/account/ route.ts
Token iptali / oturum yönetimi	✓ uygulandı	lib/token-revocation.ts , app/api/auth/logout* , app/ api/auth/sessions
Refresh yarışı	✓ uygulandı	app/api/auth/mobile-re- fresh/route.ts
Mağaza satın alma doğrulaması	✓ kod tamam, yapılandırma bekliyor	lib/store-billing.ts , app/ api/billing/google-play/ verify
SSE Last-Event-ID	✓ uygulandı	lib/sse-resume.ts + 6 kanal
Koltuk yarış koşulu	✓ uygulandı	app/api/chat/rooms/[room- Id]/seats/route.ts
Negatif bakiye	✓ uygulandı	lib/balance-guard.ts + ver- itabanı CHECK kısıtları
Uç sınıflandırması	✓ üretildi	endpoint_classification.md / .json
Zorunlu güncelleme	✓ zaten vardı	app/api/mobile/config/ route.ts

Hâlâ eksik (ürün kararı gerektirir)

- Telefon numarası ile **giriş** (login) — OTP yalnız doğrulama için eklendi
- Sosyal giriş (Facebook)
- RTMP/HLS (mimari tercih: TRTC/WebRTC)

§21 yeni karar: BÜYÜK ÖLÇÜDE HAZIR (MOSTLY READY)

Google Play / Apple mağaza yapılandırması ve SMS sağlayıcı bilgileri tamamlandığında **HAZIR** seviyesine çıkar.

BÖLÜM 27 — 2026-09-12 BÖLÜM 17 EKLEMELERİ (e-posta/telefon doğrulama, iade, Apple IAP)

BÖLÜM 26'da "ürün kararı gerektirir" olarak bırakılan 4 maddeden 3'ü **gerçek kod olarak uygulandı** (telefon ile login hariç). Tümü eklemeli; hiçbir mevcut uç veya tablo değişmedi.

Özellik	Uçlar	Yapılandırma
E-posta doğrulama	POST /api/auth/email/send-verification , POST+GET /api/auth/email/verify	Hazır (mevcut e-posta altyapısı)
Telefon/SMS OTP	POST /api/auth/phone/send-otp , POST /api/auth/phone/verify-otp	SMS_PROVIDER + sağlayıcı creds bekliyor → yoksa 503
Kullanıcı tarafı iade	POST+GET /api/refunds , GET+PATCH /api/admin/refunds	Hazır
Apple App Store doğrulama	POST /api/billing/app-store/verify	APPLE_IAP_SHARED_SECRET bekliyor → yoksa 503

Yeni tablolar (eklemeli): `email_verification_tokens` , `phone_otps` , `refund_requests` . `User` alanı: `phoneVerified Boolean @default(false)` .

Apple ve Google Play ürün eşlemesi **ortak** `store_products_map` ayarını ve ortak `lib/store-grant.ts` tanımlama mantığını kullanır. Detaylar: `authentication.md` ve `gifts_coins_wallet_api.md` .

Değişmeyenler (mevcut web sitesi korundu)

- Hiçbir mevcut uç kaldırılmadı veya imzası değiştirilmedi.
- Veritabanı şeması yalnız **eklemeli** değişti (4 yeni tablo); mevcut tablolar, kullanıcılar, jetonlar, CFC bakiyeleri, Gold üyelikler, hediyeler, odalar, yayınlar ve işlem kayıtları dokunulmadan kaldı.
- Flutter için **ayrı backend veya ayrı veritabanı oluşturulmadı**; web ve mobil tek backend, tek veritabanı kullanır.